

🌐 Penetration Testing Report

Tester: Solomon Mwaura

Date: April 14, 2026

Role: Junior Penetration Tester

📋 Executive Summary

A full-scope penetration test was performed on a Linux-based target (Metasploitable 3) at 192.168.100.29. The goal was to identify weaknesses, demonstrate exploitation paths, and outline actionable remediation steps.

The system was found to host multiple outdated, high-risk services, including ProFTPD 1.3.5 and Samba 4.3.11, leaving it significantly exposed to automated scanning tools and manual exploitation.

Critical exposure points included weak network filtering, open high-risk ports, and accessible web directories leaking sensitive information.

🔥 Key Findings

- Critical Vulnerabilities
 - Severely outdated services (ProFTPD, Samba, Jetty)
 - Open, unfiltered ports exposing high-value services
- Impact
 - High probability of remote compromise
 - Potential for total system takeover via SMB
 - Risk of sensitive data exfiltration via exposed directories
- Notable Observations
 - Attempted VSFTPD backdoor exploits failed due to service mismatch (ProFTPD detected instead)
 - Samba version vulnerable to remote command injection

🔧 Methodology Overview

A structured, industry-standard testing workflow was followed.

1. Reconnaissance & Enumeration

- Full-port Nmap sweep (-p-)
- Aggressive fingerprinting (-sV -A)
- Identified open ports for FTP, SSH, HTTP, SMB, MySQL, IRC, and Rails

2. Scanning & Analysis

Confirmed service versions:

- ProFTPD 1.3.5
- Samba 4.3.11
- Jetty 8
- MySQL 5.5
- Exposed web directories suggesting incomplete hardening

3. Exploitation Attempts

- Tried Samba exploit (CVE-2007-2447)
- Tested VSFTPD backdoor (failed due to version mismatch)
- Attempted payload variations (reverse & bind shells) to bypass potential filters

4. Post-Exploitation Plan (Intended)

- Privilege escalation via SUID binaries
- Persistence mechanisms (cron/scheduled tasks)

5. Ethical Constraints

- All testing limited to approved systems
- No DoS or destructive attacks used

🔍 Detailed Findings

Vulnerability	Description	Affected Service	Exploitation Steps	Impact	Evidence
Samba Command Injection	Vulnerable to usermap_script exploitation	SMB (445/TCP)	Set RPORT=445, used cmd/unix/reverse payload	Potential full root compromise	Port 445 open; exploitation attempt executed
ProFTPD 1.3.5 Exposure	Outdated FTP service allows information leakage	FTP (21/TCP)	Attempted VSFTPD exploit (mismatch detected)	Possible unauthorized access	Nmap banner confirms ProFTPD 1.3.5
Web Directory Exposure	Directory listing enabled; sensitive files exposed	HTTP (80/TCP)	Viewed /chat/, /drupal/, payroll_app.php	File disclosure, reconnaissance risk	Nmap HTTP output shows public listings

📊 Impact Analysis

- Likelihood of Exploitation: High
Outdated services and open ports make it ideal for automated exploits.
- Business Impact: Severe
Compromise of SMB or MySQL could expose customer data, credentials, and system files.
- Severity Rating: Critical

🛡️ Remediation Recommendations

1. Update Vulnerable Services

- Upgrade ProFTPD → latest stable (1.3.8+)
- Update Samba → patch for CVE-2007-2447

2. Firewall Re-Hardening

- Restrict 445 and 139 to internal, trusted IP ranges
- Disable unused ports:
 - 6697 (IRC)
 - 3500 (RoR service)

3. Web Server Hardening

- Disable directory listings
Options -Indexes in Apache configuration
- Review all publicly accessible web directories

4. Credential Hygiene

- Set strong MySQL root password
- Disable remote MySQL login
- Audit user accounts for misuse

🏁 Conclusion & Professional Reflection

The assessment successfully mapped a broad attack surface and revealed significant weaknesses due to outdated service versions and insufficient firewall rules.

What Went Well

- Full-port scan enabled quick identification of critical services
- Accurate service fingerprinting prevented wasted time on incompatible exploits

Challenges

- Initial assumption of VSFTPD cost time until banner review clarified ProFTPD presence
- Samba exploit executed but failed to return a proper session

Future Improvement

- Further manual exploitation of payroll_app.php for possible SQLi
- Deeper web application testing to complement system-level exploitation